

CyberGov Handbook

Key concepts and terms for Cybersecurity Governance Committee members.

Purpose and Charter:

The official purpose of CyberGov is defined in the CyberGov Charter, which is formally ratified at the first meeting and annually thereafter. Establishing clear governance of cybersecurity risk is a key focus area from customers, auditors, insurers, the Board of Directors, legal/regulatory reviewers, and other third-parties seeking assurance. CyberGov serves as a regular standing venue where the direction and mission of the cybersecurity program are set and reviewed, key activities and metrics are shared, and stakeholders outside cybersecurity are engaged when collaboration or assistance is needed.

1. Administrative Matters

Approval of Previous Meeting Minutes

The committee Chair or a delegated observer will record meeting minutes for regular approval.

Policy Changes

CyberGov is the venue where artifacts needing documented approval are submitted. In cases where additional approval bodies such as an executive committee or Board committee need to demonstrate oversight, CyberGov is used as a working group to gain agreement and *endorse* a key document for official approval. Beyond satisfying needs to demonstrate program maturity, CyberGov is the venue where stakeholders that will be impacted by policy changes have an opportunity to challenge ideas initiated within cybersecurity management. Further, socializing changes through the non-cyber stakeholders in CyberGov allows them to prepare their departments for behavioral changes needed for compliance as early as possible and show a unified front with security versus surprise.

Policy Waivers (Exceptions)

There will be occasions where the risks outweigh the rewards of forcing immediate compliance with specific policies. Examples may include allowing more time for a legacy application to gain conformance with technical security requirements or allowing a specific contractor to access specific systems remotely. In these cases waivers will be approved for a specific time period by CyberGov and reviewed regularly to ensure attention.

Organizational Updates

Talent management is a key concern for cybersecurity. Hiring and retention updates will be reviewed in addition to the key functions and organization of cybersecurity resources so CyberGov members can offer input and gain understanding of key roles and purposes.

2. Threats

Threat Objectives

Cybersecurity is a vast and rapidly-growing discipline with daily headlines about breaking risks and hacks and conflicted parties often delivering the news. It can be overwhelming to react to every article or solicitation, so a critical first step is to define the most pressing concerns to the company. Cybersecurity leadership will bring *threat intelligence* - or curated and validated information about the latest threat activity - to CyberGov to ensure focus is placed on realistic, probable concerns. It is helpful to organize threats by *Threat Objective*, which focuses on what an adversary is looking to accomplish. While the universe of Threat Objectives remains fairly constant, each maps to different adversaries, tactics, relevant vulnerabilities and effective controls that change over time. The *inherent risk* of each Threat Objective will be established and tracked to represent the mission of the program. Since risk is the product of *likelihood* and *impact*, each will be evaluated separately. Likelihood is best informed by threat intelligence and monitoring attempted and successful attacks across the world. The cybersecurity team must monitor this information and bring any updates that can affect likelihood to CyberGov. Inherent impact, on the other hand, is best established in concert with business strategists. Cybersecurity leadership can process intelligence to give an idea of what a specific threat objective such as *Extortion* or *PII Theft* might look like technically, such as “imagine we receive an email showing a sample of our confidential data with a specific threat to publish it online unless 10 Bitcoin are sent to an anonymous wallet address in the next 5 days”. Further, cybersecurity management can posit an inherent impact value based on their familiarity with the business environment and goals. Only senior business leadership, however, can fully evaluate the operational, financial, and reputational impact that might result from such an event. CyberGov serves as the primary venue for that discussion and analysis, and even if additional committees up through the Board of Directors are used to formally ratify the values, the most detailed deliberation and candid discussion will occur in CyberGov.

Risk Appetite

Risk Appetite is a key term sought by third parties to articulate how much risk an organization is willing to accept. Risk appetite does not have to be defined in quantitative financial terms, and doing so can be extremely difficult. Non-financial quantitative terms can be helpful, however, and made available as metrics are defined around the program. Examples can include the number of incidents of a specific severity per quarter, the number of days a critical risk may remain unremediated, or the amount of time that can pass between risk assessment activities of certain types.

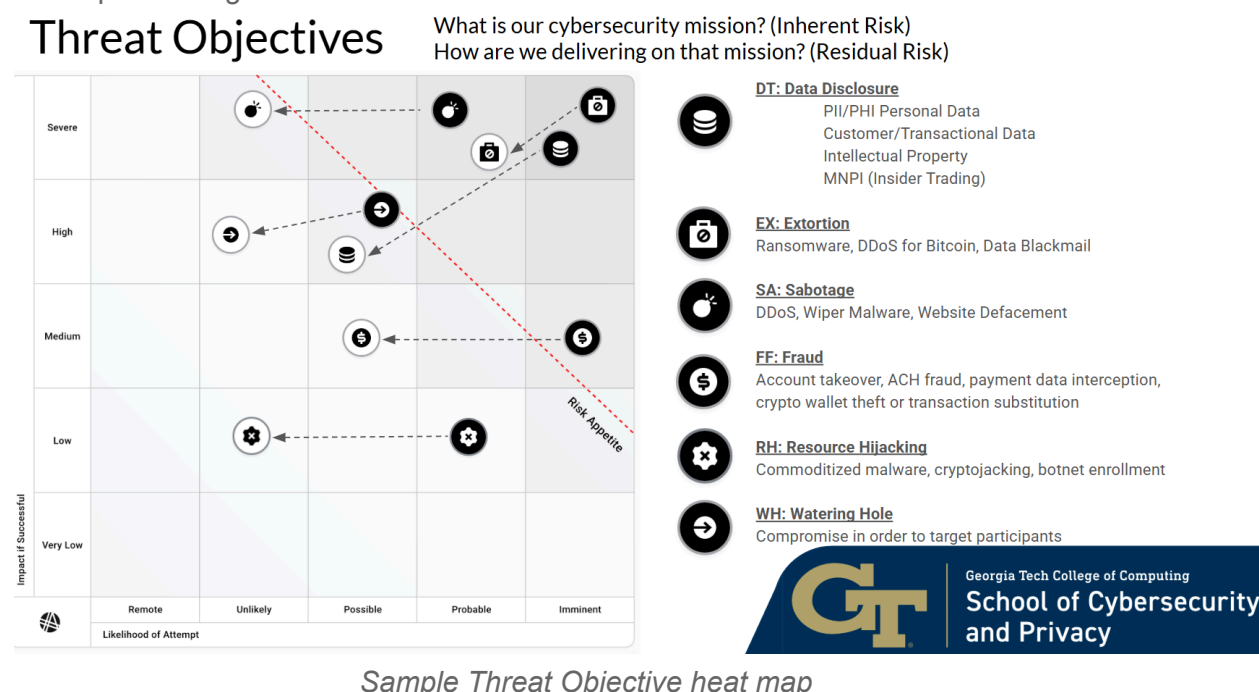
Cybersecurity Strategy

Once agreed, the inherent risk of Threat Objectives, Risk Appetite of leadership, resulting cybersecurity mission, key program activities, and performance indicators will

be memorialized in a *Cybersecurity Strategy* document that can be reviewed and updated every 3 years and made available as a key document in third party review.

Visualization

The Threat Objectives are modeled on a traditional risk heat map with likelihood on the x-axis and impact on the y-axis. Security leadership will bring proposed scores and adjustments at each CyberGov session with evidence for inherent likelihood scores. The inherent impact scores, however, will be estimates that require business-level review. Below is a sample Threat Objective heat map. In this case Data Theft ranks as the firms' highest inherent risks, which in turn would drive an emphasis on testing those scenarios and implementing related controls.



3. Risks

Risk Management is the practice of proactively identifying, scoring, and reacting to *potential* events. Risks are often confused with *Incidents* but must be documented and handled separately. Risks are negative outcomes that *could* happen, while incidents are outcomes that *have* happened. The distinction is critical in cybersecurity program management and ties directly to third party notification requirements.

RAMP

The Risk Assessment Management Procedure (RAMP) defines the processes, roles, responsibilities, and standards necessary to operate a repeatable and effective cybersecurity risk management operation. While the RAMP is an operational document that does not require CyberGov approval for changes, CyberGov will be given visibility into the Procedure for awareness and feedback.

Risk Identification Activity

The implementation, frequency, and coverage of identification activities will be summarized in CyberGov. Examples of identification activities that may be considered for adoption include:

- Attack Surface Management Programs
- Brand Monitoring
- Bug Bounty Programs
- Recurring Red Team (ethical hacking) tests prioritized by Threat Objectives
- Vulnerability Scanning
- Static Code Analysis Scanning (SAST)
- Application Security Design Reviews
- Dynamic Application Testing (DAST)
- (Open) Source Code Composition Analysis tools (SCA)
- Cloud Configuration Analysis tools

Scoring and SLAs

The urgency of a risk is calculated by the likelihood that the risk could materialize and the resulting impact if it were materialized. While Threat Objectives use a similar scoring system at the strategic level, Risks are specific and can reflect any situation, vulnerability, configuration, or practice that may contribute or directly lead to a negative outcome. The likelihood of a specific risk should factor *exploitability* and *exposure* above all else. In practice this means assessing whether an adversary would require advanced internal access to exploit a risk versus whether it would be possible via the public internet immediately. Risks that can be exploited by unaffiliated strangers across the world will see a maximal likelihood rating. Risks that can be exploited by authorized external parties such as customers or suppliers will score a notch lower, and those that are limited to employees and other parties under company controls further lower. Finally, risks that require a high degree of elevated privilege to compromise have their likelihood further reduced. The Impact of risks should be assessed based on the agreed impact of the Threat Objectives to which exploitation could lead.

In addition to the urgency scoring practices for risks, the RAMP defines the expected service level agreement - or SLA - for remediation.

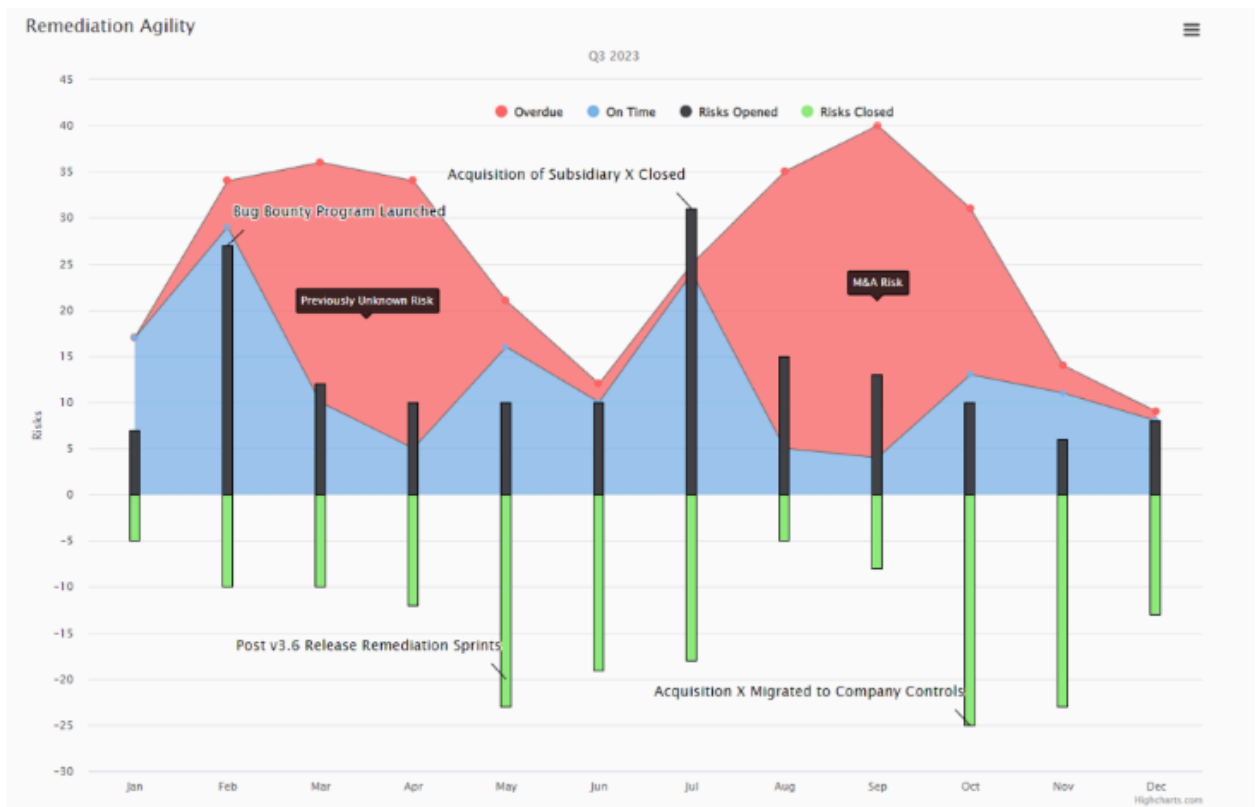
Range	Urgency	SLA
80-100	<i>CRIT</i>	30 days
50-79	<i>HIGH</i>	90 days
40-49	<i>MED</i>	180
26-39	<i>LOW</i>	365
0-25	<i>INFO</i>	n/a

Sample risk SLA chart

Remediation Agility

While Risk Identification Activity will inform how much risk discovery is taking place, Remediation Agility will focus on how quickly the organization is able to remediate findings.

Governance should see risks reported not only by the quantity of risks identified in each urgency level - with a focus on the most urgent - but further broken down by those within their agreed SLAs versus those that have exceeded agreed remediation timelines. The resulting *Remediation Agility* analysis should show the amount and quality of risk identified activity being conducted, the amount of important findings being unearthed, and the capacity of the remediating parties to address issues timely.



Sample Remediation Agility chart

Trends and Themes

The volume and nature of specific security findings may shed light on thematic areas for improvement such as secure coding education, change control enhancements, or increased monitoring.

4. Incidents

While Risks are proactive, Incident reporting is reactive and reflects risks that have been realized. The cybersecurity incident management platform instance and scoring system should be independent from its operational counterpart (e.g. non-cyber outages, natural events, or human error), though it is beneficial for owners of each system to collaborate closely, offer guidance to each other's processes, and aim for parallel constructs where possible. Separation is important for confidentiality, as the operation of cybersecurity incident detection and response will periodically generate what could be construed as false accusations. Further, cyber incidents will contain alerting and investigation details that can tip off an adversary before they can be caught. Separation of operational and cyber incidents is also important because while both programs will factor the impact of an incident in severity, cyber incident management should also include targeted malicious intent as a criterion so that incidents that identify the presence of a motivated adversary are given increased focus and attention.

High Severity Incidents

Using an established severity criteria agreed via policy approval, incidents of a moderately high severity should be explicitly listed for review with CyberGov. Criteria of "targeted malicious intent" or operational impact should limit the number of incidents to a digestible amount.

Trends and Themes

Tracking incident counts by severity level will inform CyberGov of the incident response team workload and draw attention to business changes or security projects that influenced the volume of incidents.

5. Compliance

Attestations

Attestations can include formal audits and reports such as ISO27001 or SOC2, where CyberGov is a valuable venue to prepare potential interviewees and document producers for upcoming audits. Progress and results will be summarized for the committee.

Inbound Third-party Risk Management (TPRM) Queries

Since customer audits and security assertions can consume a great deal of

cybersecurity resources, the number and intensity of such reviews will be reported to CyberGov.

Outbound TPRM

Security reviews of suppliers will communicate the criteria and review processes conducted, with metrics showing the “funnel” of activity to demonstrate screening criteria and final results.

6. Controls

Control Selection

The proactive management of Threats and reactive mitigation of identified risks will generate a program of control selection and implementation. Because controls can have significant impacts on the operation of business functions, CyberGov will be made aware of significant control decisions and given the opportunity to collectively review the potential impacts of those choices and steer deployment to minimize disruption. Examples can range from blocking new categories of web sites to changing requirements for length and complexity of passwords.

Implementation Status and Blockers

Each CyberGov meeting will also provide an element of project tracking on longer-timeframe initiatives intended to remediate thematic risks or improve risk identification and management processes.